

Exercice – Analyse d'un incident de sécurité chez MEDILINK CARE

MEDILINK CARE exploite une plateforme de télésurveillance médicale utilisée par plusieurs établissements de santé pour le suivi de patients atteints de pathologies chroniques. La plateforme permet aux professionnels de santé d'accéder aux données médicales des patients, de consulter des alertes issues de dispositifs connectés et d'échanger des informations médicales via un espace sécurisé.

Un lundi matin, le service support est contacté par un établissement partenaire signalant que certains professionnels de santé constatent la présence, dans leur espace applicatif, de dossiers patients qui ne relèvent pas de leur périmètre habituel. Dans le même temps, un autre établissement indique avoir reçu par erreur, via la plateforme, un compte rendu médical concernant un patient suivi dans une autre structure.

Une analyse préliminaire menée par les équipes IT montre qu'un compte utilisateur appartenant à un professionnel de santé récemment muté a conservé des droits d'accès étendus à plusieurs périmètres applicatifs. Ce compte avait été créé plusieurs mois auparavant et n'avait pas fait l'objet d'une revue de droits récente. L'authentification reposait uniquement sur un identifiant et un mot de passe.

L'incident n'a pas été détecté automatiquement par les systèmes de surveillance. Il a été signalé uniquement après remontée des utilisateurs. Les journaux applicatifs disponibles permettent de constater des accès anormaux à certains dossiers médicaux, mais ces journaux ne sont ni centralisés ni analysés de manière régulière.

Suite à la découverte de l'incident, MEDILINK CARE a suspendu le compte concerné et a informé les établissements impactés. Une analyse plus approfondie est en cours afin d'évaluer l'étendue exacte des accès non autorisés et de déterminer si une notification aux autorités compétentes est nécessaire. Cet événement soulève des inquiétudes importantes concernant la protection des données de santé, la conformité réglementaire et la confiance des partenaires.

1. Identifier les **mesures de prévention** qui auraient permis d'éviter la survenue de l'incident
2. Identifier les **mesures de détection** qui auraient permis de détecter l'incident plus rapidement
3. Identifier les **mesures de correction** qui permettent de traiter l'incident et d'éviter sa récurrence

